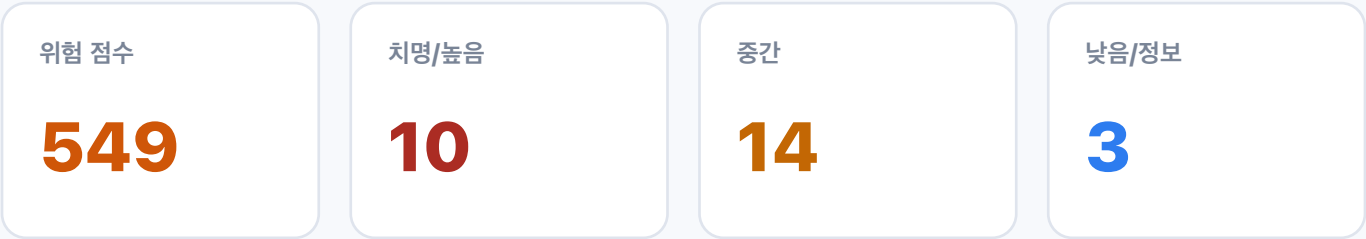


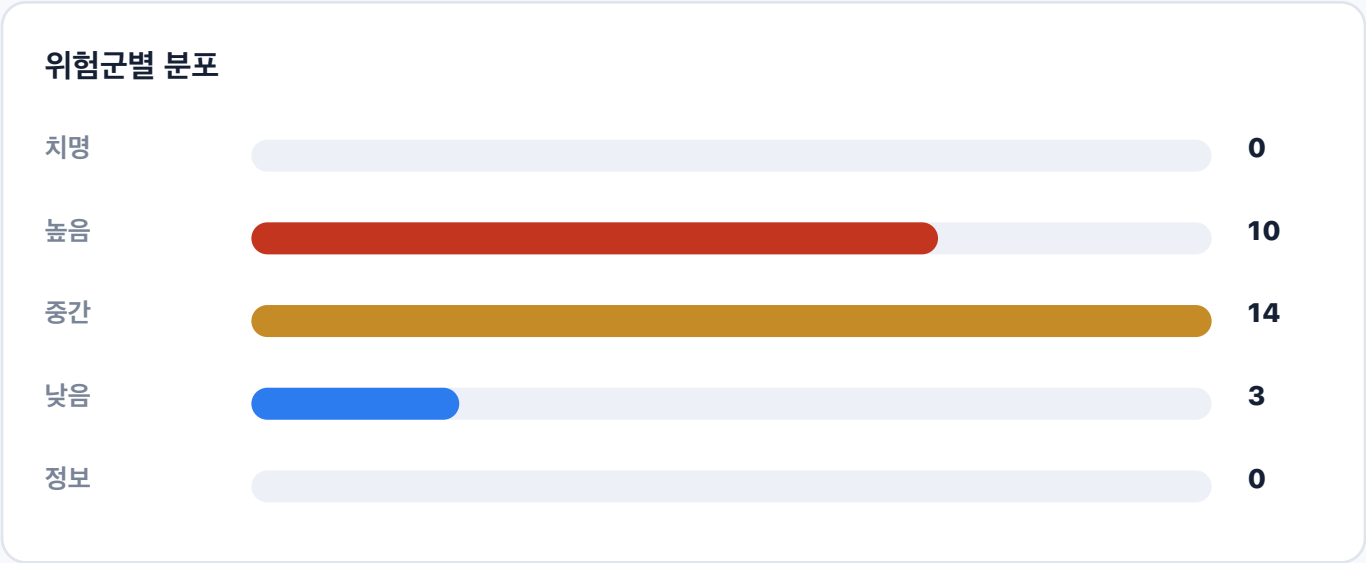
KODA 보안 점검 리포트

생성 시각 2026-05-15 22:14:30 | 점검 대상 1 | 스캔 파일 84



위험점수 계산

위험 점수는 치명 100점, 높음 40점, 중간 10점, 낮음 3점, 정보 1점을 발견 항목별로 더한 값입니다.



발견 항목

발견 항목 27 | 위험 점수 549

심각도	발견 항목	경로	근거 / 조치
높음	사용자 입력 URL 요청으로 인한 SSRF 위험 code.ssrp-user-url 코드 패턴	security/docs/security-dashboard-research.md:49	근거: - Code-pattern heuristics: common risky sinks such as dynamic SQL, unsafe HTML rendering, shell execution, path use, SSRF fetches, disabled CSRF/auth checks, unsafe deserialization, file upload saves, request body parsin 조치: 허용된 호스트만 요청하고 사설망
높음	Compose 서비스가 Docker socket 을 마운트함 config.compose-docker-sock 설정	security/platforms/macos/KODA/KODA/NativeSecurityScanner.s wift:1085	근거: if line.lowercased().contains("/var/run/docker.sock") { 조치: Docker socket 마운트를 피하거
높음	위험한 역직렬화 사용 code.unsafe-deserialization 코드 패턴	security/platforms/macos/KODA/KODA/NativeSecurityScanner.s wift:1132	근거: if matches("#"(?) (pickle .loads yaml .load ObjectInputStream unserialize)"#, line) { 조치: 신뢰할 수 없는 입력의 역직렬화를
높음	사용자 입력 URL 요청으로 인한 SSRF 위험 code.ssrp-user-url 코드 패턴	security/platforms/macos/KODA/KODA/NativeSecurityScanner.s wift:1135	근거: if matches("#"(?) \\b(requests httpx urllib .request axios fetch http .get https .get RestTemplate WebClient).*(get post open request \\ .)*(req . request . \$_(GET POST REQUEST FILES) params query body location .input (\\s 조치: 허용된 호스트만 요청하고 사설망
높음	XML 외부 엔티티 처리가 허용될 수 있음 code.xml-external-entity 코드 패턴	security/platforms/macos/KODA/KODA/NativeSecurityScanner.s wift:1183	근거: if matches("#"(?) (resolve_entities\\s*=\\s*True load_dtd\\s*=\\s*True DocumentBuilderFactory SAXParserFactory XmlReaderSettings XmlDocument)"#, line) {
높음	권한 상승 컨테이너 설정 config.compose-privileged 설정	security/ security_scanner/ checks/ configuration.py:170	근거: if lowered == "privileged: true": 조치: 컨테이너 privileged 모드를 제거 하고 필요한 capability만 부여하세요.
높음	Compose 서비스가 Docker socket 을 마운트함 config.compose-docker-sock 설정	security/ security_scanner/ checks/ configuration.py:198	근거: if "/var/run/docker.sock" in lowered: 조치: Docker socket 마운트를 피하거 나 제한된 프록시를 사용하세요.

발견 항목

발견 항목 27 | 위험 점수 549

심각도	발견 항목	경로	근거 / 조치
높음	권한 상승 컨테이너 설정 config.compose-privileged 설정	security/tests/ test_scanner.py:85	근거: "services:\n app:\n privileged: true\n", 조치: 컨테이너 privileged 모드를 제거 하고 필요한 capability만 부여하세요.
높음	DOM XSS 위험 sink code.xss-dom-sink 코드 패턴	security/tests/ test_scanner.py:456	근거: archive.writestr("web/ views.js", "document.body.innerHTML = location.hash\n") 조치: 신뢰할 수 없는 입력을 HTML로 직 접 삽입하지 말고 escaping 또는
높음	DOM XSS 위험 sink code.xss-dom-sink 코드 패턴	security/tests/ test_scanner.py:647	근거: "document.body.innerHTML = location.hash\n", 조치: 신뢰할 수 없는 입력을 HTML로 직 접 삽입하지 말고 escaping 또는 textContent를 사용하세요.
중간	환경 파일이 프로젝트에 포함됨 config.env-file-present 설정	security/.env.example	근거: .env.example 조치: 비밀값 포함 여부를 확인하고 저장 소에서 제외하세요.
중간	경로 조작 위험 code.path-traversal 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1120	근거: if matches("#"(?i)(send_file sendfile readFile createReadStream).*(request req .params query)"#, line) { 조치: 사용자 입력 경로를 정규화하고 허 용된 루트 내부인지 검증하세요.
중간	CSRF 보호가 비활성화된 것으로 보임 code.csrf-disabled 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1123	근거: if matches("#"(?i) (@csrf_exempt csrf\s*:\s*false csrf .disable verify_csrf_token.*false skip_before_action\s+:verify_aut henticity_token protect_from_forgery\s+except:) "#, line) {
중간	인증 또는 인가가 우회된 엔드포인트 code.auth-disabled-endpoint 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1126	근거: if matches("#"(?i) (@AllowAnonymous @Public(\) permitAll(\) auth\s*:\s*false AllowAnonymous permission_classes\s*=\s*\[\s*\] skip_before_action\s+:authent icate)"#, line) { 조치: 공개 의도가 명확한지 확인하고 민

발견 항목

발견 항목 27 | 위험 점수 549

심각도	발견 항목	경로	근거 / 조치
중간	와일드카드 CORS 설정 code.wildcard-cors 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1162	근거: if matches("#"(?) (CORS Access-Control-Allow- Origin).*(* origins\\s*=\\s*[\\\" \\\")"#, line) { 조치: 허용 origin을 명시적으로 제한하세요
중간	레거시 게시판 소프트웨어 흔적 code.legacy-board-software 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1180	근거: if matches("#"(?) \\b(technote zeroboard)\\b"#, line) { 조치: 컴포넌트 사용 여부를 확인하고 최
중간	WebDAV 활성화 흔적 code.webdav-enabled 코드 패턴	security/platforms/ macos/KODA/KODA/ NativeSecurityScanner.s wift:1976	근거: case "code.webdav- enabled": return "WebDAV enabled" 조치: 필요하지 않은 WebDAV 기능을 비
중간	와일드카드 CORS 설정 code.wildcard-cors 코드 패턴	security/ security_scanner/ checks/ code_patterns.py:269	근거: r"(Access-Control-Allow- Origin[\\\"]?\\s*[\\\"]\\s* allow_origins\\s*=\\s*[\\\"]\\s* " 조치: 허용 origin을 명시적으로 제한하세 요.
중간	레거시 게시판 소프트웨어 흔적 code.legacy-board-software 코드 패턴	security/ security_scanner/ standards.py:1170	근거: "technote", 조치: 컴포넌트 사용 여부를 확인하고 최 신 버전으로 교체하거나 제거하세요.
중간	레거시 게시판 소프트웨어 흔적 code.legacy-board-software 코드 패턴	security/ security_scanner/ standards.py:1171	근거: {"en": "Technote", "ko": "테 크노트"}, 조치: 컴포넌트 사용 여부를 확인하고 최 신 버전으로 교체하거나 제거하세요.
중간	레거시 게시판 소프트웨어 흔적 code.legacy-board-software 코드 패턴	security/ security_scanner/ standards.py:1176	근거: "zeroboard", 조치: 컴포넌트 사용 여부를 확인하고 최 신 버전으로 교체하거나 제거하세요.
중간	레거시 게시판 소프트웨어 흔적 code.legacy-board-software 코드 패턴	security/ security_scanner/ standards.py:1177	근거: {"en": "Zeroboard", "ko": "제 로보드"}, 조치: 컴포넌트 사용 여부를 확인하고 최 신 버전으로 교체하거나 제거하세요.
중간	디렉터리 리스팅 활성화 code.directory-listing-enabled 코드 패턴	security/tests/ test_scanner.py:826	근거: (root / ".htaccess").write_text("Options Indexes\\n", encoding="utf-8") 조치: 디렉터리 인덱싱을 비활성화하세요.

발견 항목

발견 항목 27 | 위험 점수 549

심각도	발견 항목	경로	근거 / 조치
중간	WebDAV 활성화 흔적 code.webdav-enabled 코드 패턴	security/tests/ test_scanner.py:827	근거: (root / "web.config").write_text("<add name=\"WebDAVModule\" />\n", encoding="utf-8") 조치: 필요하지 않은 WebDAV 기능을 비
낮음	개발 환경 플래그가 설정됨 config.development-environment 설정	security/.env.example:2	근거: APP_ENV=development 조치: 배포 설정과 로컬 개발 설정을 분리 하세요.
낮음	개발 환경 플래그가 설정됨 config.development-environment 설정	security/platforms/ macos/KODA/KODA/ ScannerBridge.swift:203 7	근거: APP_ENV=development 조치: 배포 설정과 로컬 개발 설정을 분리 하세요.
낮음	개발 환경 플래그가 설정됨 config.development-environment 설정	security/ security_scanner/ toolkit.py:158	근거: APP_ENV=development 조치: 배포 설정과 로컬 개발 설정을 분리 하세요.